

Discovery Executive Summary

Project: discovery-14-aug · Generated: 14/08/2026, 11:56:51

EXECUTIVE SUMMARY

This report consolidates the overall ratings, key findings, and recommended actions from the 1 discovery analysis run across this codebase (frontend and backend). Each section below reproduces that analysis's executive view; full evidence and diagrams live in the individual reports.

Portfolio Overview

#	Analysis	Overall Rating
1	Backend Modernization Analysis	—

1. Backend Modernization Analysis

EXECUTIVE SUMMARY

The Klearcom backend is a PHP 8.3 / Laravel 12 monolith serving a Voice & Telecom QA platform with two feature modules (Discovery and Connect) backed by MariaDB and MongoDB. The most severe gaps are the complete absence of authentication and authorization on all 19 API endpoints, the use of `extract()` on raw user input creating untraceable variable injection, and database schema managed via raw SQL init scripts with no migration framework and no FK indexes. Controllers contain inline ORM queries and duplicated business logic (reachability calculation appears in three places; `buildTree` is copy-pasted across two controllers) instead of delegating to a service layer. No rate limiting, no security headers, no caching layer, no linter enforcement in CI, and CORS is configured as wildcard `*` — the backend is functionally unprotected. The API surface has no OpenAPI spec, no versioning, and no contract tests.

4.1 Benchmark Ratings Summary

#	Hotspot	Primary KPI	Good	Moderate	High Risk	Measured	Rating
H1	Dynamic Variable Creation	Dynamic-var-from-input occurrences	0	1–10	>10	3 (extract calls; 1 on raw \$request->all())	Moderate
H2	Global Mutable State	Globals / mutable static state	0	1–5	>5	0	Good
H3	Direct SQL Outside Data Layer	Data-layer compliance %	>90%	60–90%	<60%	~15% (only MongoService queries in a service; all Eloquent ORM in controllers)	High Risk
H4	Static / Singleton Abuse	Business-logic static/singleton classes	0	1–5	>5	0 (static calls are Eloquent facade usage, not custom singletons)	Good
H5	Missing Service Layer	Handlers with inline business logic	<10	10–20	>20	4 controllers with inline business logic + duplicated logic across files	Moderate
H6	API Sprawl	Documented & governed endpoints %	>90%	80–90%	<80%	0% — no OpenAPI spec, no documentation	High Risk
H7	Missing API Governance	Governance compliance %	100%	90–99%	<90%	0% — no spec, no versioning, no contract tests, no API linting	High Risk
H8	Weak Application Architecture	Modules following declared architecture %	>80%	50–80%	<50%	~33% — only MongoController and StreamController delegate to services (2 of 6)	High Risk
H9	Missing Module Inventory	Circular dependency count	0	1–3	>3	0	Good
H10	Database Schema Weakness	FK indexes % + migrations with rollback %	Both >90%	One <90%	Both <90%	0% explicit FK indexes on non-FK-constraint columns (parent_id) + 0% migration rollback (raw SQL init, no Laravel migrations)	High Risk

H11	Middleware Weakness	Required middleware present + ordered %	100%	80–99%	<80%	~20% — only CORS present; no auth, no rate limiting, no security headers, no request logging	High Risk
H12	Auth & Authorization Weakness	Protected routes guarded % + hashing algo	100% + bcrypt/argon2	One gap	Both bad	0% routes guarded + no password hashing (no auth system)	High Risk
H13	Backend Security Vulnerabilities	Injection + hardcoded secrets count	0 each	1–3 total	>3 total	7 total (1 extract-injection on \$request->all(), wildcard CORS, 4 plaintext passwords in docker-compose + CI, hardcoded KPI values)	High Risk
H14	Performance & Caching Gaps	N+1 patterns found	0	1–5	>5	1 (LegacyReportController::carrierSummary loops monitors with per-monitor query) + zero caching	Moderate
H15	Outdated & Vulnerable Dependencies	Critical/High CVEs found	0	1–3	>3	0 (no composer.lock to audit; only 3 production deps, all latest)	Good
H16	Secrets & Configuration in Source	Hardcoded secrets / .env committed	0	1–2	>2	3 (.env.example with DB_PASSWORD=secret, docker-compose.yml with 3 plaintext passwords, CI workflow with hardcoded passwords)	High Risk
H17	Backend Code Quality	Linters in CI + max cyclomatic complexity	Both good	One gap	Both bad	No linter in CI (phpstan in require-dev but not run) + no complexity enforcement	High Risk
H18	Missing Transaction Boundaries (additional)	Multi-step DB writes without transaction wrapping	0	1–3	>3	4 (RealTimeTestService multi-model writes in runDiscoveryTest and runConnectTest)	Moderate

4.4 Actions Required

Hotspot	Action	Rating	Priority
H12 — Auth & Authorization	Add Laravel Sanctum auth middleware to all non-health routes; add user password column; implement object-level authorization policies	High Risk	Critical
H11 — Middleware Weakness	Add auth, rate limiting, security headers, request logging middleware; restrict CORS origins	High Risk	Critical
H1 — Dynamic Variable Creation	Remove all extract() calls; use Form Request validation with explicit field access	Moderate	Critical
H13 — Security Vulnerabilities	Eliminate extract-injection, move secrets to env/vault, use GitHub Actions secrets in CI, remove hardcoded KPIs	High Risk	Critical
H10 — Database Schema Weakness	Convert raw SQL to Laravel migrations with rollback; add index on parent_id	High Risk	Critical
H3 — Direct ORM in Controllers	Create Repository classes for all 4 models; move all Eloquent queries out of controllers	High Risk	High
H8 — Weak Architecture	Enforce service-layer pattern across all controllers; add deprec/PHPStan rules to prevent Model calls from Controllers	High Risk	High
H5 — Missing Service Layer	Extract ReachabilityService, IvTreeService, DashboardService to eliminate duplicated logic	Moderate	High
H16 — Secrets in Source	Move docker-compose and CI passwords to Docker secrets and GitHub Actions secrets	High Risk	High
H7 — Missing API Governance	Generate OpenAPI spec, add API versioning, add contract tests and Spectral linting to CI	High Risk	High
H6 — API Sprawl	Standardize response envelope, document all endpoints, add version prefix	High Risk	Medium
H17 — Code Quality	Configure phpstan.neon at level 6+, add phpstan + Pint to CI, replace non-deterministic tests	High Risk	High
H14 — Performance & Caching	Add eager loading for N+1, introduce Redis caching for dashboard and carrier summary	Moderate	Medium
H18 — Missing Transactions	Wrap multi-model writes in DB::transaction; add error handling in dispatch closures	Moderate	Medium

4.5 Expected Outcomes

- **Authentication eliminates unauthorized access:** Adding Sanctum auth middleware to all routes prevents anonymous users from triggering telephony tests (which incur carrier costs) and accessing sensitive monitoring data.

- **extract()** removal eliminates variable injection risk: Replacing `extract($request->all())` with typed Form Requests closes the most critical injection vector, making data flow explicit and auditable.
- **Service layer enables logic reuse:** Extracting `ReachabilityService` and `IvrTreeService` eliminates the three duplicated reachability calculations and two duplicated `buildTree` methods, creating single sources of truth.
- **Repository layer decouples persistence:** Moving ORM queries into repositories allows controllers to be tested without a database and enables future storage changes without touching business logic.
- **Migration framework prevents schema drift:** Converting raw SQL to Laravel migrations with `down()` methods enables version-controlled, rollback-capable schema changes and eliminates environment drift.
- **API governance prevents breaking changes:** An OpenAPI spec with contract tests in CI ensures that API changes are detected before they reach consumers, and versioning enables non-breaking API evolution.
- **Redis caching reduces database load:** Caching dashboard KPIs and carrier summaries eliminates repetitive aggregate queries, reducing database load by an estimated 80%+ on read-heavy endpoints.
- **CI quality gates catch regressions early:** Enforcing PHPStan level 6+ and Laravel Pint in CI catches type errors, undefined variables, and style violations before they reach production."


```
"stop_reason":"end_turn","session_id":"69585a1a-58a3-4cee-a538-26f8b0dab47b","total_cost_usd":2.42277,"usage":
{"input_tokens":17,"cache_creation_input_tokens":109039,"cache_read_input_tokens":866972,"output_tokens":35536,"server_tool_use":
{"web_search_requests":0,"web_fetch_requests":0},"service_tier":"standard","cache_creation":
{"ephemeral_1h_input_tokens":109039,"ephemeral_5m_input_tokens":0},"inference_geo":"not_available","iterations":
[{"input_tokens":1,"output_tokens":3042,"cache_read_input_tokens":96250,"cache_creation_input_tokens":12789,"cache_creation":
{"ephemeral_5m_input_tokens":0,"ephemeral_1h_input_tokens":12789},"type":"message"}],"speed":"standard"},"modelUsage":{"claude-haiku-4-5-20251001":
{"inputTokens":10339,"outputTokens":14,"cacheReadInputTokens":0,"cacheCreationInputTokens":0,"webSearchRequests":0,"costUSD":0.010409,"contextWindow":200000,"maxOutputTokens":3200
opus-4-6":
{"inputTokens":17,"outputTokens":35536,"cacheReadInputTokens":866972,"cacheCreationInputTokens":109039,"webSearchRequests":0,"costUSD":2.4123609999999998,"contextWindow":200000,"
[],"terminal_reason":"completed","fast_mode_state":"off","uuid":"391a1bac-4f76-4172-95f6-8b865c36f88b"}
```